

สรุปสาระสำคัญ พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562

กฎหมายว่าด้วยข้อมูลที่คุณต้องรู้
เพื่อยกระดับความน่าเชื่อถือขององค์กร



PDPA คืออะไร ?



PDPA ย่อมาจาก PERSONAL DATA PROTECTION ACT

คือ พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล

บัญญัติให้ความคุ้มครองข้อมูลส่วนบุคคลของ

**“บุคคลธรรมดา” โดยให้สิทธิในการแก้ไข เข้าถึง แจ้งลบข้อมูล
ที่ได้ให้ไว้กับองค์กร**

และกำหนดบทบาทหน้าที่ และบทลงโทษหากองค์กรไม่ปฏิบัติตาม



ทำไมต้องมี PDPA?



EU GDPR
มาตรฐานโลก



PDPA B.E. 2562
มาตรฐานไทย



ยกระดับสู่มาตรฐานสากล
เทียบเคียงกับมาตรฐานระดับโลก



ปกป้องสิทธิขั้นพื้นฐาน
เปลี่ยนข้อมูลจาก ของฟรีที่ทุกคนเข้าถึงได้
สู่สิทธิที่ต้องคุ้มครอง



เพิ่มความน่าเชื่อถือ
สร้างความมั่นใจให้ลูกค้าและพันธมิตร

ข้อมูลส่วนบุคคลทั่วไป (Personal Data)

ข้อมูลใด ๆ ที่สามารถระบุตัวบุคคลนั้นได้
(ระบุไปถึงเจ้าของข้อมูล)
ไม่ว่าจะเป็นทางตรงหรือทางอ้อมก็ตาม
แต่จะไม่รวมถึงข้อมูลของผู้ที่เสียชีวิตแล้ว
หรือ ข้อมูลของนิติบุคคล
เช่น บริษัท มูลนิธิ สมาคม องค์กร

ตัวอย่าง

- ชื่อ-นามสกุล หรือชื่อเล่น
- เลขประจำตัวประชาชน, เลขหนังสือเดินทาง, เลขบัตรประกันสังคม, เลขใบอนุญาตขับขี่, เลขประจำตัวผู้เสียภาษี, เลขบัญชีธนาคาร, เลขบัตรเครดิต (การเก็บเป็นภาพสำเนาบัตรประชาชนหรือสำเนาบัตรอื่น ๆ ที่มีข้อมูลส่วนบุคคลที่กล่าวมาย่อมสามารถใช้ระบุตัวบุคคลได้โดยตัวมันเอง จึงถือเป็นข้อมูลส่วนบุคคล)
- ที่อยู่, อีเมล, เลขโทรศัพท์
- ข้อมูลอุปกรณ์หรือเครื่องมือ เช่น IP address, MAC address, Cookie ID
- ข้อมูลระบุทรัพย์สินของบุคคล เช่น ทะเบียนรถยนต์, โฉนดที่ดิน
- ข้อมูลที่สามารถเชื่อมโยงไปยังข้อมูลข้างต้นได้ เช่น วันเกิดและสถานที่เกิด, เชื้อชาติ, สัญชาติ, น้ำหนัก, ส่วนสูง, ข้อมูลตำแหน่งที่อยู่ (location), ข้อมูลการแพทย์, ข้อมูลการศึกษา, ข้อมูลทางการเงิน, ข้อมูลการจ้างงาน
- ข้อมูลหมายเลขอ้างอิงที่เก็บไว้ในโมโครฟิล์ม แม้ไม่สามารถระบุไปถึงตัวบุคคลได้ แต่หากใช้ร่วมกับระบบดัชนีข้อมูลอีกระบบหนึ่งก็จะสามารถระบุไปถึงตัวบุคคลได้
- ข้อมูลการประเมินผลการทำงานหรือความเห็นของนายจ้างต่อการทำงานของลูกจ้าง
- ข้อมูลบันทึกต่าง ๆ ที่ใช้ติดตามตรวจสอบกิจกรรมต่าง ๆ ของบุคคล เช่น log file
- ข้อมูลที่สามารถใช้ในการค้นหาข้อมูลส่วนบุคคลอื่นในอินเทอร์เน็ต

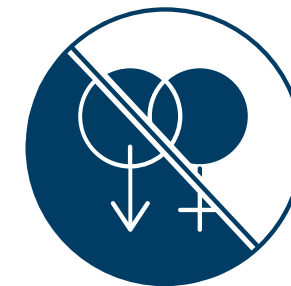
ข้อมูลส่วนบุคคลที่อ่อนไหว (Sensitive Personal Data)



ต้องคุ้มครองข้อมูลสุด

1. เชื้อชาติ
2. เผ่าพันธุ์
3. ความคิดเห็นทางการเมือง
4. ความเชื่อในลัทธิ ศาสนาหรือปรัชญา
5. พฤติกรรมทางเพศ
6. ประวัติอาชญากรรม
7. ข้อมูลสุขภาพ ความพิการ หรือข้อมูลสุขภาพจิต
8. ข้อมูลสภาพแรงงาน
9. ข้อมูลทางชีวมิติ (Biometric) เช่น รูปภาพใบหน้า, ลายนิ้วมือ, พัลมเอกซ์เรย์, ข้อมูลสแกนม่านตา, ข้อมูลอัตลักษณ์เสียง, ข้อมูลพันธุกรรม
10. ข้อมูลอื่นใดซึ่งกระทบต่อเจ้าของข้อมูลในทำนองเดียวกันตามที่คณะกรรมการประกาศกำหนด

ข้อมูลส่วนบุคคลที่มีลักษณะเฉพาะตัวของบุคคล เป็นเรื่องที่จะเอื้ออำนวยและมีความเสี่ยงสูงต่อการถูกนำไปใช้ในการเลือกปฏิบัติอย่างไม่เป็นธรรม ดังนั้นจึงจำเป็นต้องดำเนินการด้วยความระมัดระวังเป็นพิเศษเมื่อจัดการกับข้อมูลดังกล่าว



ความเสี่ยงของข้อมูลส่วนบุคคล



ถูกขโมยตัวตน
เพื่อใช้ก่ออาชญากรรม



การขายข้อมูล



การประมวลผลข้อมูล



การติดตาม
สอดแนม

3 บทบาทสำคัญ ในระบบ PDPA

ผู้ควบคุมข้อมูล (Data Controller)

องค์กรที่มีอำนาจตัดสินใจ
ในการเก็บหรือใช้ข้อมูล
มีความรับผิดชอบหลัก
ในการปฏิบัติตาม PDPA
และกำหนดมาตรการ
การรักษาความปลอดภัย

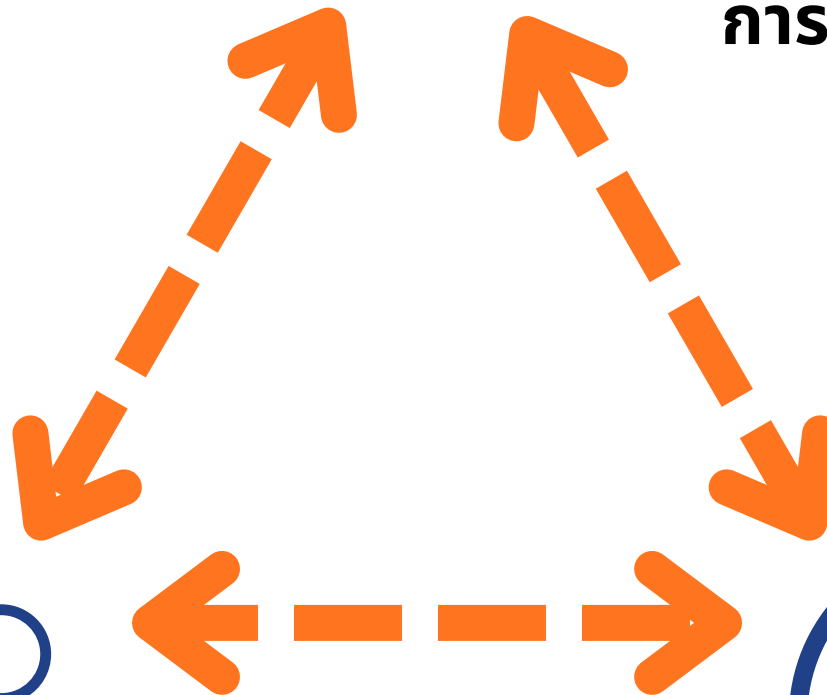


เจ้าของข้อมูล (Data Subject)

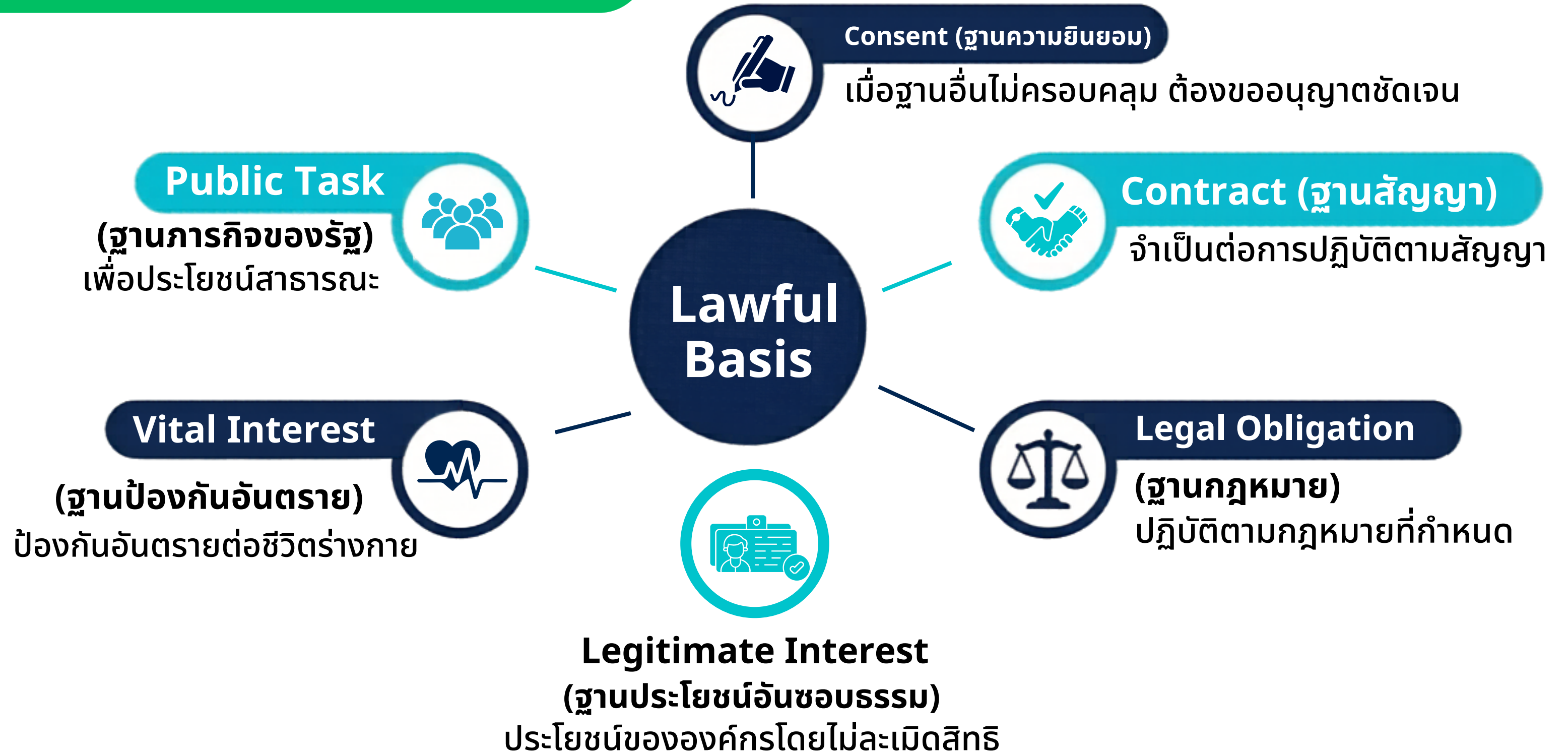
ลูกค้า, พนักงาน หรือบุคคลทั่วไปที่ระบุตัวตนได้
มีสิทธิเข้าถึง, ขอแก้ไข, ขอให้ลบ, หรือคัดค้าน
การประมวลผลข้อมูลของตน

ผู้ประมวลผลข้อมูล (Data Processor)

ผู้รับจ้างที่ประมวลผลข้อมูลตามคำ
สั่งเท่านั้น ต้องปฏิบัติตามข้อตกลง
และมีมาตรการรักษาความปลอดภัย
ที่เหมาะสม (เช่น Cloud, Agency,
Outsourced IT)



6 ฐานความชอบด้วยกฎหมาย (ไม่จำเป็นต้องขอความยินยอมเสมอไป)



กฎเหล็กของการขอความยินยอม (Consent)



สิ่งที่ต้องทำ (DO)

- ✓ แยกชัดเจนออกจากข้อตกลงและเงื่อนไขอื่นๆ (T&C)
- ✓ ใช้ภาษาที่อ่านง่าย ไม่หลอกลวงหรือทำให้เข้าใจผิด
- ✓ ถอนความยินยอมได้ง่ายเสมอ



สิ่งห้ามทำ (DON'T)

- ✗ ห้ามทำช่องทำเครื่องหมายล่วงหน้า (No pre-ticked boxes)
- ✗ ห้ามผูกมัดเงื่อนไข หากข้อมูลนั้นไม่จำเป็นต่อการให้บริการ

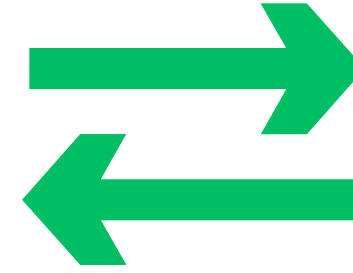
7 สิทธิของเจ้าของข้อมูล



สิทธิได้รับ
การแจ้งให้ทราบ



สิทธิขอเข้าถึงข้อมูล



สิทธิขอให้ โอน
ข้อมูล ส่วนบุคคล



สิทธิ คัดค้านการเก็บ
รวบรวม ใช้หรือเปิดเผย
ข้อมูลส่วนบุคคล



สิทธิขอให้ ลบหรือทำลาย หรือทำให้
ข้อมูลส่วนบุคคลเป็นข้อมูล
ที่ไม่สามารถระบุตัวบุคคลได้



สิทธิขอให้ ระงับการใช้
ข้อมูล ส่วนบุคคล

หน้าที่หลักของผู้ควบคุมข้อมูล (Data Controller)

Data Breach Notification

ต้องแจ้งเหตุข้อมูลรั่วไหล
แก่สำนักงานฯ ภายใน 72 ชั่วโมง

Purpose Limitation

เก็บ ใช้ หรือเปิดเผยข้อมูล
ตามวัตถุประสงค์ที่แจ้งไว้เท่านั้น

Privacy Notice

แจ้งรายละเอียดและวัตถุประสงค์
ให้ทราบก่อนหรือขณะเก็บรวบรวม

Security Measures

จัดให้มีมาตรการ
การรักษาความมั่นคงปลอดภัย
ที่เหมาะสม

การทำงานระหว่างผู้ควบคุมข้อมูล และ ผู้ประมวลผลข้อมูล



ผู้ประมวลผลข้อมูล (Data Processor)

- ทำตามคำสั่งที่ระบุไว้ในสัญญาเท่านั้น
- จัดทำบันทึกรายการประมวลผล (ROPA)
- ให้ความร่วมมือเมื่อมีการเข้าตรวจสอบ
- ส่งต่อคำร้อง (เช่น ขอลบข้อมูล) ให้องค์กร



ผู้ควบคุมข้อมูล (Data Controller)

- ตรวจสอบว่าคำสั่งนั้นชอบด้วยกฎหมาย
- ตรวจสอบความถูกต้องของบันทึก
- ดำเนินการหรือกำกับการตรวจสอบ (Audit)
- บริหารจัดการให้คำร้องเสร็จสิ้นตามกำหนด

การส่งข้อมูลไปต่างประเทศ (Cross-Border Transfers)



หลักการสำคัญ:

ประเทศปลายทางต้องมี

“มาตรฐานการคุ้มครองข้อมูลเพียงพอ”

ข้อยกเว้น:

- ได้รับความยินยอมหลังแจ้งความเสี่ยงแล้ว
- จำเป็นต่อการปฏิบัติตามสัญญา
- มีนโยบายคุ้มครองข้อมูลภายในองค์กรที่ได้รับการรับรอง (BCR)

บทลงโทษหากฝ่าฝืน (The Consequences)



โทษทางแพ่ง

ชดใช้ค่าสินไหมทดแทน
ที่เกิดขึ้นจริง
ให้กับเจ้าของข้อมูลส่วนบุคคล
ที่ได้รับความเสียหาย
จากการละเมิด
และอาจจะต้องจ่ายบวกเพิ่มอีก
เป็นค่าค่าสินไหมทดแทน
เพื่อการลงโทษเพิ่มเติมสูงสุด
ได้อีก 2 เท่าของค่าเสียหายจริง



โทษทางอาญา

มีทั้งโทษจำคุกและโทษปรับ
โดยมี โทษจำคุกสูงสุดไม่เกิน 1 ปี
หรือ ปรับไม่เกิน 1 ล้านบาท
หรือทั้งจำทั้งปรับ
กรณีหากผู้กระทำความผิด คือ บริษัท
(นิติบุคคล)
ผู้บริหาร, กรรมการ หรือบุคคล
ซึ่งรับผิดชอบในการดำเนินงาน
ของบริษัทนั้น ๆ
ต้องได้รับการลงโทษจำคุก



โทษทางปกครอง

ตั้งแต่ 1 ล้านบาท
จนถึงสูงสุดไม่เกิน 5 ล้านบาท
ซึ่งโทษปรับสูงสุด 5 ล้านบาท
จะเป็นกรณีของการไม่ปฏิบัติตาม PDPA
ในส่วนการใช้ข้อมูล
หรือ เปิดเผยข้อมูล หรือส่งโอนข้อมูลไปยัง
ต่างประเทศ
ของประเภทข้อมูลที่มีความละเอียดอ่อน
ซึ่งโทษทางปกครองนี้จะแยกต่างหาก
กับการชดใช้ค่าเสียหายที่เกิดจากโทษ
ทางแพ่งและโทษทางอาญาด้วย

เริ่มต้นอย่างไร? (Action Plan)



1. สำรวจข้อมูล (Data Mapping)

สำรวจว่าองค์กรมีข้อมูลอะไร เก็บที่ไหน และใครเข้าถึงได้

2. จัดทำนโยบาย (Privacy Policy)

ร่าง Privacy Notice และปรับปรุงฟอร์มขอความยินยอม

3. ยกระดับความปลอดภัย

ทบทวนระบบ IT Security และสัญญา DPA กับผู้ให้ประมวลผลข้อมูล

4. อบรมและแต่งตั้ง

ວັດໄອ

- <https://www.youtube.com/watch?v=5KKISgyAv-Y>
- <https://youtu.be/zCVI9CK4b8g?si=U2u85-Z70v3pCKXf>

น้ำโซดามะนาว vs มะเร็ง

• 











จะเชื่อได้จริงหรือ?

PDPA ไม่ใช่แค่เรื่องของการทำตามกฎหมาย
แต่คือการสร้าง **'ความไว้วางใจ'** ในยุคดิจิทัล
